Escalating to Domain Admin in Microsoft's Cloud Hosted Active Directory (Azure AD Domain Services)

trimarcsecurity.com/hub-post/escalating-to-domain-admin-in-microsoft-s-cloud-hosted-active-directory-azure-ad-domain-services

Sean Metcalf September 3, 2020

Updated: Dec 13, 2024

While preparing for my DEFCON 28 SafeMode talk in 2020, I reviewed hosted Active Directory (AD) environments from the three big cloud providers: Amazon, Microsoft, and Google. This review involved running a version of the Trimarc Active Directory Security Assessment Tool which is a custom, internal, proprietary program we run during Active Directory Security Assessments (ADSAs). The assessment tool we use is effectively an advanced AD recon tool that highlights potential security issues in the AD environment. For DEFCON I wanted to include a review of how each cloud provider configured AD to provide access to customers without providing Domain Admin rights.

Hosted AD environments have some similarities:

- The hosted AD environment is created from a template and configured per customer by the cloud provider.
- The hosted AD environment is 100% managed AD by the cloud provider.
- Customer does not get Domain Admin rights or access to Domain Controllers.
- There are groups created that are delegated specific rights to Active Directory so the customer can perform typical actions such as creating and modify users, groups, and computer accounts.

This article is focused on an interesting configuration I identified in the Microsoft Azure AD Domain Services environment which is Microsoft's hosted AD. I will post an article later with my full review of the hosted AD environments.

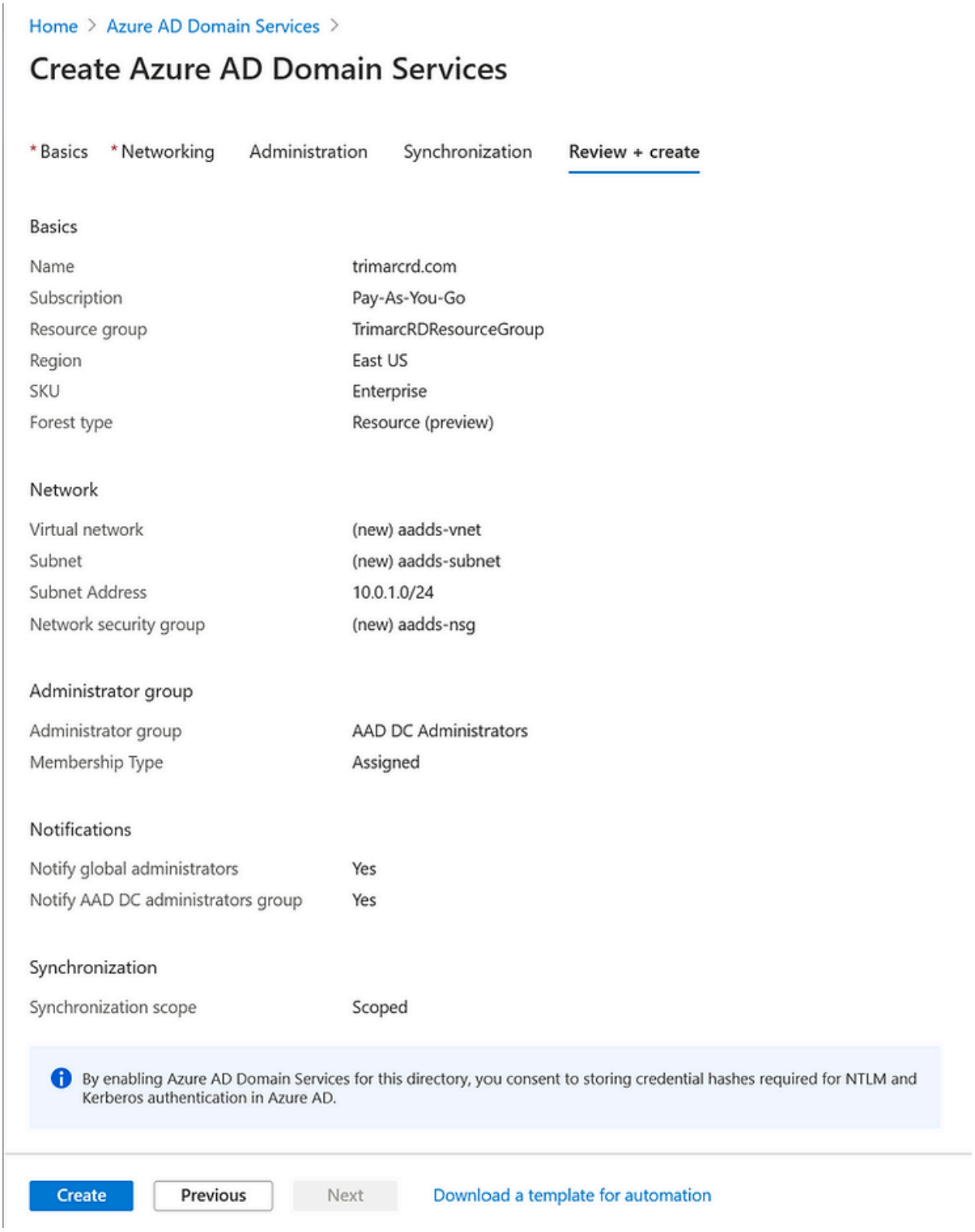
It's important to note here that Azure Active Directory (Azure AD) is not the same as Active Directory that is deployed on-premises. Azure AD is a version of AD designed as a cloud directory that supports cloud authentication protocols. I cover Azure AD in more detail in an article called "What is Azure AD".

Azure AD Domain Services

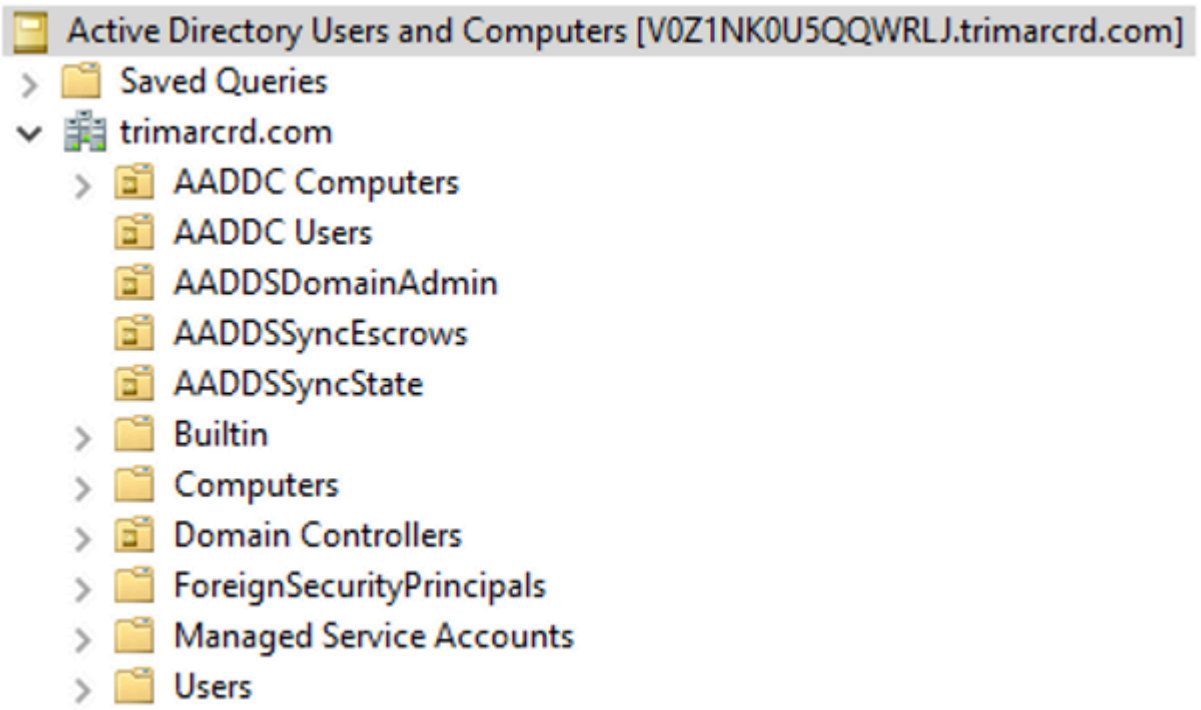
Microsoft Azure Active Directory Domain Services (aka Azure AD DS) is Microsoft's version of cloud hosted Active Directory which is the same Active Directory that organizations have deployed on-prem. However there are some differences with Microsoft's cloud hosted AD

related to customer access. The customer has no access to Domain Controllers or their configuration.

Once the customer initiates the creation of the Azure AD Domain Services hosted AD environment, there is a screen presented which displays some information about the environment. The following screenshot shows this information.



The hosted AD environment has Organizational Units (OUs) built out to provide delegated administration. The following screenshot shows the OU structure.



Azure AD DS provides delegation groups which are prefixed with “AAD DC” and are in the “AADDC Users” OU. The primary customer group is “AAD DC Administrators” which is delegated Full Control to many OUs and AD components. The Azure AD account used to create Azure AD DS is the first member of the AAD DC Administrators group.

The DNSAdmins group provides the ability to manage DNS on Domain Controllers. In Azure AD Domain Services, the delegation group "AAD DC Administrators" is added to the DNSAdmins group providing DNS administration capability to the managed AD environment for the customer. The customer is provided membership and the ability to manage membership of "AAD DC Administrators".

> **Important**
>
> You don't have *Domain Administrator* or *Enterprise Administrator* permissions on a managed domain using Azure AD DS. These permissions are reserved by the service and aren't made available to users within the tenant.
>
> Instead, the *AAD DC Administrators* group lets you perform some privileged operations. These operations include belonging to the administration group on domain-joined VMs, and configuring Group Policy.

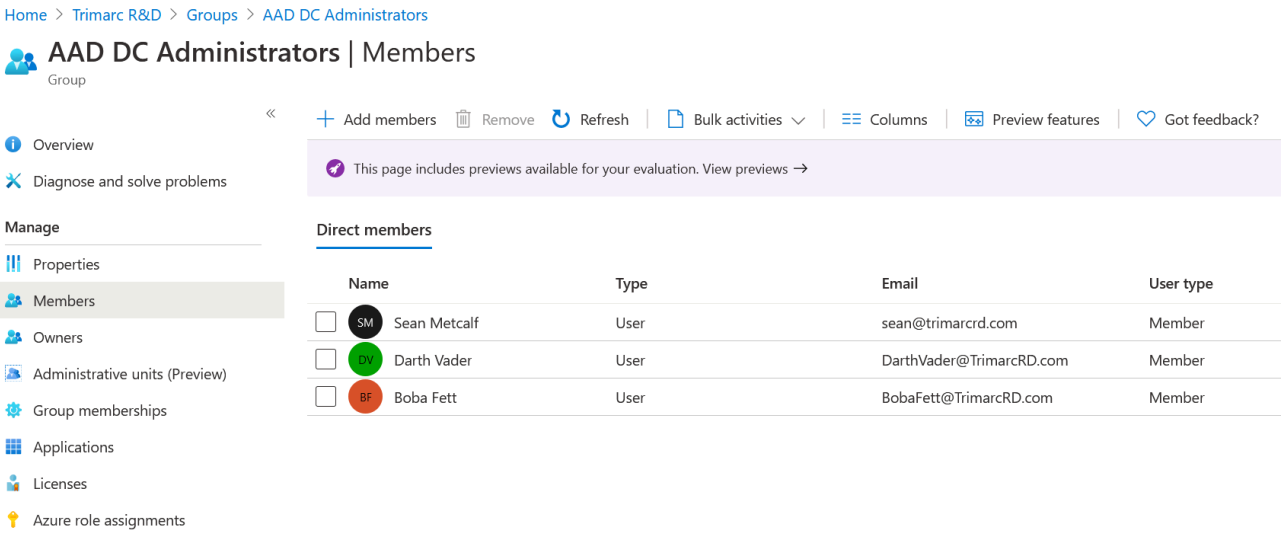
Azure AD DS Synchronized Accounts

Azure AD DS can be managed by Azure AD accounts that are synchronized into Azure AD DS. This also includes on-prem AD accounts synchronized from the on-prem Active Directory through Azure AD Connect (via Azure AD) to Azure AD DS. If Password Hash

Sync (PHS) is enabled, then the on-prem AD account hash is included in this synchronized data so the account can authenticate to Azure AD DS using the same credentials as on-prem AD.

This means that if on-prem AD accounts are synchronized to Azure AD DS and an attacker could compromise the on-prem account, they could leverage this account in Azure AD DS. If the Azure AD DS synched account is a member of AAD DC Administrators, then the attacker would have Azure AD DS delegated management capability to the hosted AD.

Another interesting thing about Azure AD DS and its connection to Azure AD is that the "AAD DC Administrators" group is in Azure AD and the membership synchronized into Azure AD DS (thanks to @NicNicNad on Twitter for the tip). Any role that can modify groups in Azure AD have the ability to modify this group as well as the "AAD DS Password Sync" group in Azure AD which appears to control which on-prem accounts synchronize their password hash to Azure AD DS.

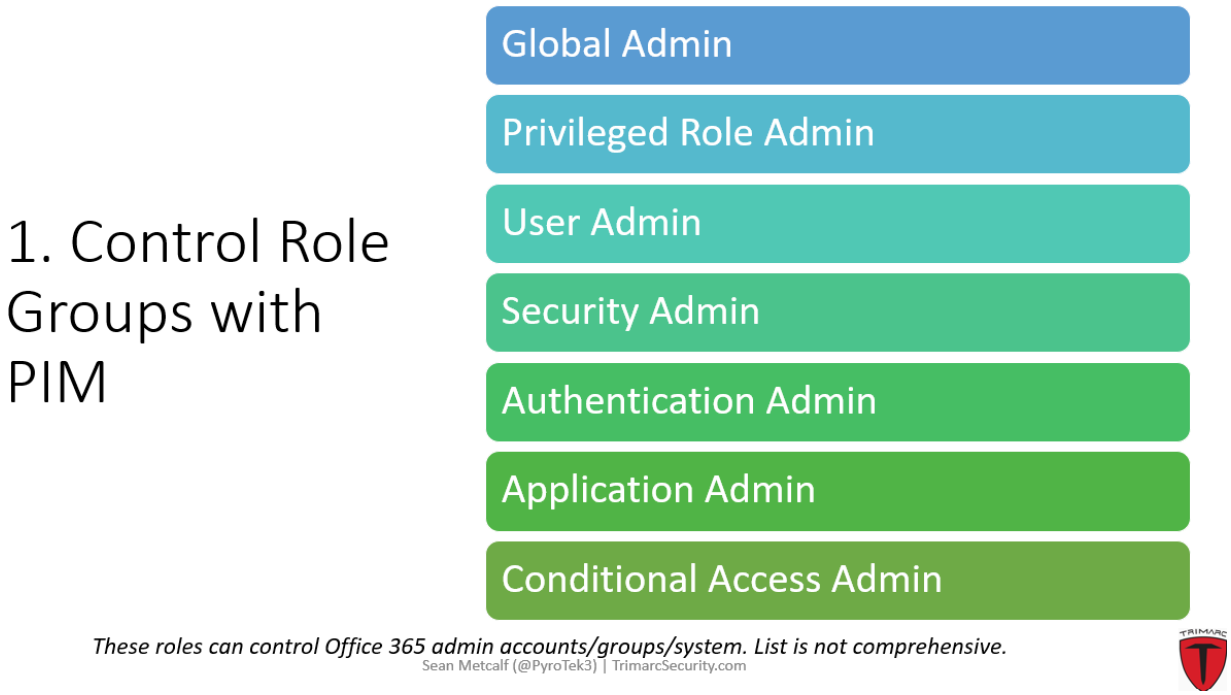


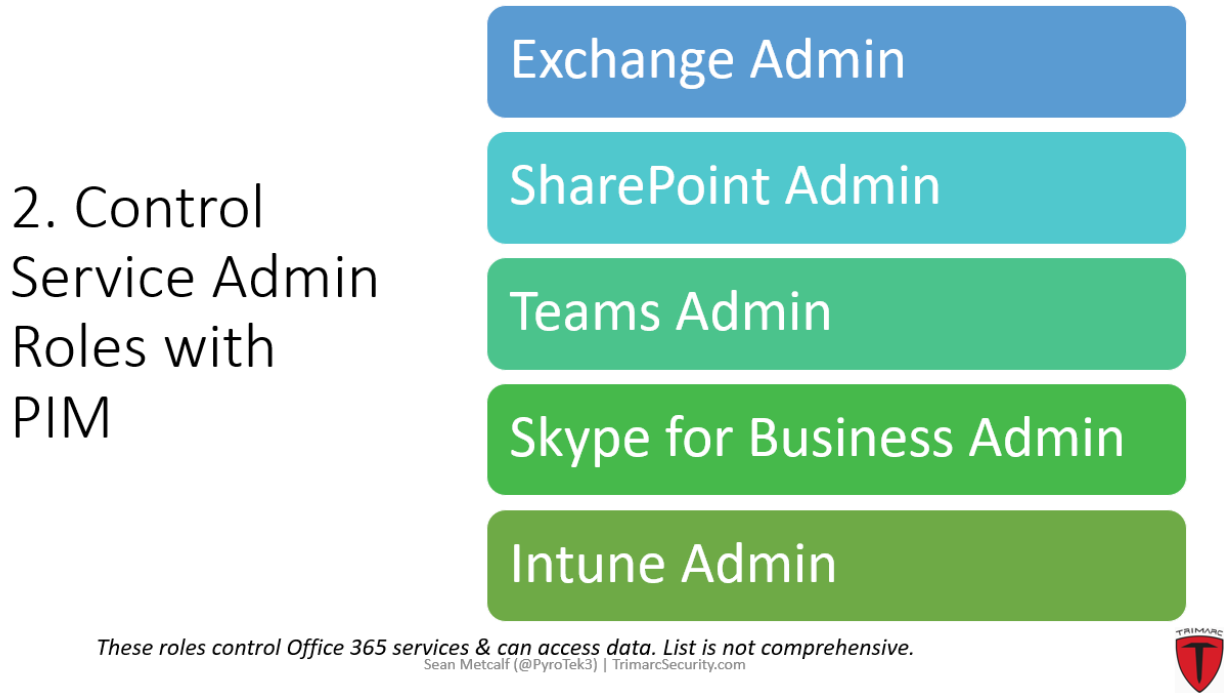
Azure AD Roles which can modify Azure AD groups:

- Groups Administrator
- Intune Administrator
- User Administrator

Compromise of any account in one of these groups could result in compromise of the Azure AD DS. Additionally, compromise of any account in a group that can control Azure AD would have the same result.

Additional role groups that have the ability to control Azure AD should be managed with Azure AD Privileged Identity Manager (PIM). Here is an excerpt from the Trimarc Webcast on Securing Office 365 & Azure AD earlier in 2020.





The Issue

There is a known issue with DNSAdmins in Active Directory having the ability to run a DLL from a share on the Domain Controller which I learned about from a Medium post by Shay Ber. The DNS service simply needs to be restarted after loading the DLL remotely (typically done after patches are applied monthly). This would provide SYSTEM rights on the Domain Controller which would lead to privileged AD rights. If an attacker could compromise a customer account in the Azure AD Domain Services domain (or synchronized from on-prem AD or Azure AD) that is a member of the "AAD DC Administrators" group or has the ability to modify this group, the attacker could

compromise the Azure AD Domain Services domain and persist at the Domain Controller and/or domain level without the customer's knowledge or ability to resolve.

It's also important to note that the primary driver for leveraging a cloud hosted Active Directory environment is ease of use and simplified management, often for application management. This means that application owners will often have accounts in the delegation groups that provide management capability. This may result in accounts with more privileges than required by putting accounts directly in AAD DC Administrators group since it's not Domain Admins.

I reiterate this point since it's important: customers leveraging Azure AD DS are more likely to use the AAD DC Administrators group for administration since it's not Domain Admins and is by definition limited. This can result in a larger attack surface due to the issues described in the Medium article.

Key Items with this Escalation

- DNS management is performed over RPC (UUID is 50ABC2A4–574D-40B3–9D66-EE4FD5FBA076) and the transport mechanism is the \PIPE\DNSSERVER named pipe.
- According to Microsoft protocol specification, the "ServerLevelPluginDll" operation enables us to load a dll of our choosing (with no verification of dll path).
- dnscmd.exe already implements this option: *dnscmd.exe /config /serverlevelplugindll \\path\to\dll*
- When executing this dnscmd.exe command as a user that is a member of DNSAdmins, the following registry key is populated: *HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\services\DNS\Parameters\ServerLevelPluginDll*
- Restarting the DNS service will load the DLL in this path; however, the DLL needs to contain "one of the DnsPluginInitialize, DnsPluginCleanup or DnsPluginQuery exports."
- The DLL can be modified in order to load properly and allow the DNS service to start successfully (https://medium.com/techzap/dns-admin-privesc-in-active-directory-ad-windows-ecc7ed5a21a2).
- The DLL simply needs to be available on a network share that the Domain Controller's computer account can access. So an existing instance joined to the Managed AD domain can be used to host this DLL.

Mitigation

This issue could be mitigated by either changing the service account the DNS service runs under, potentially by restricting DLLs that can operate on Domain Controllers, or Microsoft could re-open the original case and fix this as a security issue since other hosted/managed Active Directory environments may delegate the DNSAdmins group to customers which would provide potential escalation.

Based on my observations, the two other hosted AD environments I reviewed do not have the same issue.

Amazon AWS Managed Active Directory provides the delegation group “AWS Delegated Domain Name System Administrators” which is added to the DNSAdmins group providing DNS administration. While the customer has (indirect) membership in DNSAdmins, there is a managed service account that appears to run DNS services on Domain Controllers which likely mitigates this issue since the escalation described above leverages the fact that the DNS service on Domain Controllers runs as System by default.

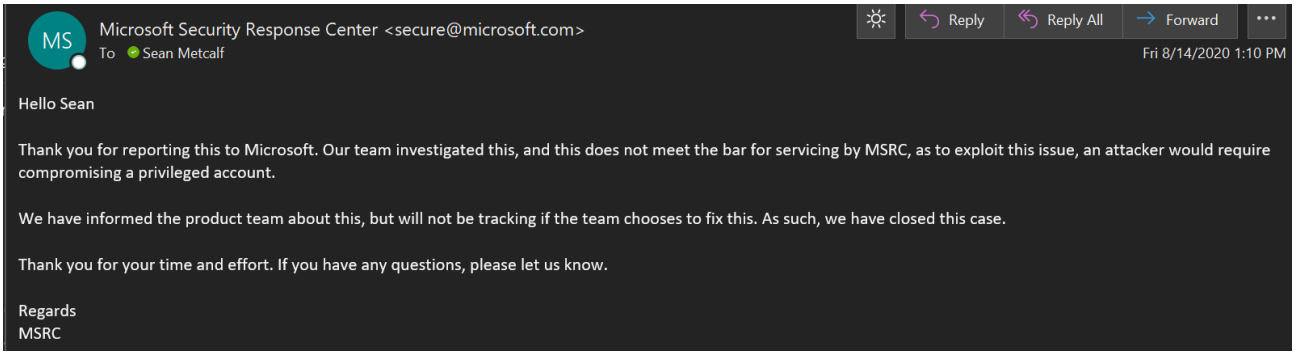
Google Cloud Platform has opted to directly delegate access to the DNS objects in Active Directory instead of delegating membership to the DNSAdmins group.

Reporting Timeline

I reported this security issue to Microsoft on June 27th (though due to some technical issues the message actually received until about a week later).

Microsoft responded on August 14th noting that this issue does not meet the bar since an attacker would require compromising a privileged account (ultimately a member of DNSAdmins).

I disagree with this assessment since the point of a cloud hosted AD environment is that a customer (or attacker) would not have full admin rights to the AD environment. This issue provides an attack path where leveraging a customer account to get Domain Admin rights in the hosted AD environment. To me, this appears to be a clear escalation above and beyond of what is expected especially since in a hosted AD environment, no one but the provider should have full AD admin rights.



Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.